

ComplyVerse Asset Discovery & Intelligence

Product and Implementation Plan

Document status: Proposed implementation blueprint **Prepared:** 15 July 2026 **Target environment:** Financial institutions and enterprises with up to 30,000 managed assets

1. Executive summary

ComplyVerse should build an **Asset Discovery & Intelligence** capability, not a standalone network scanner. Its purpose is to continuously answer four questions:

- 1 What technology assets exist?
- 2 What operating systems, applications and services run on them?
- 3 Which CIS requirements and vulnerabilities apply?
- 4 Which weaknesses should the organization remediate first?

The product must support customers that have an existing ITAM/CMDB as well as customers that have no authoritative inventory. CIDR scanning is only one optional discovery source. Active Directory, endpoint agents, authenticated remote collection, cloud APIs, hypervisor APIs, vulnerability scanners and CMDB connectors must all feed the same canonical asset inventory.

ComplyVerse already contains useful building blocks: manual and spreadsheet asset import, CIDR port probing, Active Directory enumeration, WinRM and SSH collection, a Windows/Linux endpoint agent, software normalization, host/application relationships, CIS matching, vulnerability correlation, cloud/scanner ingestion, risk scoring and a mature asset interface. The principal work is to connect these components through persistent discovery campaigns, distributed collectors, durable job queues, strong identity resolution and structured inventory history.

2. Product decision

The feature should be named **ComplyVerse Asset Intelligence**.

It should provide three complementary operating modes:

Mode A — Existing inventory

Synchronize from BMC Helix, ServiceNow CMDB, ManageEngine, VMware, Microsoft endpoint tools and similar sources. Preserve the source system as provenance while creating or updating canonical ComplyVerse assets.

Mode B — Agentless discovery

Deploy a ComplyVerse Discovery Collector inside the customer network. It discovers permitted address ranges and performs read-only authenticated collection through WinRM, SSH, SNMPv3 and supported APIs.

Mode C — Endpoint agent

Install the ComplyVerse Agent on endpoints where remote administration is unavailable, unreliable or prohibited. The agent reports identity, operating system, installed software, configuration and scan results through outbound encrypted communication.

Customers may use all three modes simultaneously. The identity service must merge observations without creating duplicate assets.

3. Scope

3.1 In scope

- Discovery campaigns, schedules, scopes and exclusions.
- Customer-side discovery collectors.
- Active Directory and CMDB enumeration.
- Network presence detection.

- Windows, Linux and network-device inventory.
- Endpoint-agent inventory.
- Cloud and virtualization discovery.
- Asset identity resolution and deduplication.
- Hardware, operating-system, software, service and interface inventory.
- First-seen, last-seen and change history.
- CIS benchmark routing and assessment initiation.
- CPE/PURL vulnerability correlation.
- Risk recalculation and remediation prioritization.
- Operational dashboards, audit logs and health monitoring.
- Multi-tenant security, credential isolation and least privilege.

3.2 Initially out of scope

- Exploit execution or penetration testing.
- Intrusive vulnerability scanning.
- Packet capture and network traffic inspection.
- Full software-license management.
- Automated remediation on customer systems.
- Real-time EDR prevention and response.

These exclusions keep the first release safe, explainable and suitable for bank approval.

4. Existing ComplyVerse baseline

The following capabilities should be reused rather than rebuilt:

Existing capability	Current implementation	Required evolution
Asset register	grc_it_assets, asset APIs and Assets Workspace	Add durable external identities, provenance and inventory relationships
CIDR discovery	Synchronous TCP port probe, maximum 4,096 addresses	Convert to queued multi-protocol discovery through collectors
AD discovery	LDAP computer enumeration and bulk onboarding	Make AD a scheduled discovery source with delta synchronization
Agentless collection	WinRM and SSH software inventory	Bind credentials/connections to targets and execute through collector jobs
Endpoint agent	Enrollment, heartbeat, inventory and result intake	Complete durable job dispatch, fleet policy and secure upgrade lifecycle
Software inventory	detected_software_json and regex normalization	Move canonical installations to relational tables with history
CIS integration	OS/software matching and plugin execution	Trigger incrementally when relevant inventory changes
Vulnerability correlation	CPE/PURL identifiers and asset links	Generate identifiers from normalized inventory and retain match evidence
Cloud/scanner connectors	AWS/Azure/GCP and Nessus/Nexpose paths	Funnel all sources through the same identity and observation pipeline

Existing capability	Current implementation	Required evolution
Risk engine	CIS, vulnerability, CIA, control and business-impact scoring	Recalculate only affected assets and preserve calculation provenance

5. Target user journey

An administrator should be able to complete the following journey:

- 1 Open **Administration** → **Asset Intelligence**.
- 2 Register or select a Discovery Collector.
- 3 Create a campaign named, for example, "Production Networks — Nightly".
- 4 Add discovery sources: AD, CIDR ranges, vCenter, cloud accounts or CMDB.
- 5 Add exclusions and safe scan windows.
- 6 Assign approved credential profiles.
- 7 Preview the estimated scope and required permissions.
- 8 Run now or schedule the campaign.
- 9 Observe live progress: queued, discovered, authenticated, inventoried, merged and failed.
- 10 Review newly discovered assets, duplicates, unmanaged devices and collection failures.
- 11 Allow ComplyVerse to run relevant CIS checks, vulnerability mapping and risk calculations.
- 12 View prioritized remediation from the asset, vulnerability, compliance and risk modules.

The campaign must be resumable and repeatable. A second run must update existing assets, not duplicate them.

6. End-to-end pipeline

Stage 1 — Scope creation

The campaign defines where ComplyVerse may look and where it must not look.

Inputs include:

- IPv4/IPv6 CIDRs and explicit hosts.
- Excluded CIDRs, hosts and sensitive systems.
- Active Directory organizational units.
- CMDB queries.
- vCenter clusters and folders.
- Cloud accounts, subscriptions, projects and regions.
- Collector assignment.
- Allowed protocols and ports.
- Maximum packets/connections per second.
- Maintenance window and recurrence.

Every campaign must require explicit tenant permission and generate an audit record.

Stage 2 — Candidate enumeration

Candidate assets are obtained from low-impact sources first:

- 1 CMDB/ITAM records.
- 2 Active Directory computer objects.
- 3 Cloud and hypervisor APIs.
- 4 Existing scanner integrations.
- 5 Previously known assets due for refresh.
- 6 Approved network ranges.

This ordered approach reduces unnecessary network traffic.

Stage 3 — Presence detection

Network discovery should combine safe techniques rather than treating one closed port as proof that a host is absent:

- ARP for collector-local subnets.
- ICMP echo when allowed.
- TCP SYN/connect probes on an approved small port set.
- UDP probes for supported protocols.
- DNS forward and reverse lookup.

The current single-port TCP probe remains useful as one signal. It must not be labeled comprehensive host discovery. SNMP normally uses UDP 161, so it requires a real SNMP client rather than the existing TCP socket check.

Output is a **discovery observation**, not immediately a trusted canonical asset.

Stage 4 — Unauthenticated fingerprinting

For each responding candidate, collect safe clues:

- DNS hostname and domain.
- MAC address where visible.
- Manufacturer from OUI.
- TLS certificate subject and issuer.
- SSH, HTTP, SMB and other permitted service banners.
- SNMP system description where authorized.
- Probable device type and OS family.
- Confidence score and evidence sources.

Fingerprint claims must remain probabilistic until authenticated evidence confirms them.

Stage 5 — Credential selection and authentication

The system chooses a credential profile based on campaign, network, domain and probable device type. It should attempt only approved profiles and implement lockout protection.

- Windows: WinRM over HTTPS using a read-only domain service account where possible.
- Linux: SSH key with restricted read-only/sudo commands.
- Network devices: SNMPv3 authPriv or restricted vendor API/SSH account.
- VMware: read-only vCenter role.
- Databases: monitoring/read-only database account.

- Cloud: least-privilege IAM role or application identity.

Authentication failures must be categorized: unreachable, timeout, bad credentials, unauthorized, certificate error, host-key error or unsupported platform.

Stage 6 — Authenticated inventory

Collect a versioned snapshot containing:

- Stable device identifiers.
- Hostname, domain and operating system.
- OS edition, version, build and patch level.
- Manufacturer, model, serial number and BIOS/VM UUID.
- CPU, memory and storage.
- Interfaces, MAC addresses and IP addresses.
- Installed packages and applications.
- Windows roles/features or Linux services.
- Running services and listening ports.
- Agent/collector metadata.
- Selected configuration values required by approved CIS checks.

Collectors must use read-only commands and impose response-size and execution-time limits.

Stage 7 — Normalization

Raw observations are converted to canonical values:

- OS: Microsoft Windows Server 2022 Datacenter → windows-server-2022.
- Software: variant SQL Server names → mssql-2022.
- Vendor names: Microsoft Corp. and Microsoft Corporation → Microsoft.
- Device categories: server, workstation, switch, router, firewall, printer, hypervisor, VM, database, cloud resource or unknown.

Raw source values must be retained for audit and troubleshooting.

Stage 8 — Identity resolution and deduplication

The identity engine compares observations using ordered identifiers:

- 1 Agent device UUID.
- 2 Cloud provider resource ID.
- 3 Hypervisor/BIOS UUID.
- 4 Hardware serial number.
- 5 AD object GUID or machine SID.
- 6 Trusted MAC address.
- 7 Fully qualified hostname.
- 8 Hostname plus IP.
- 9 IP address alone as a weak, temporary signal.

The engine returns one of four decisions:

- Match an existing asset automatically.
- Create a new canonical asset.
- Propose a possible duplicate for human review.
- Quarantine an ambiguous observation until more evidence arrives.

Manual merge and split actions must be auditable and reversible.

Stage 9 — Canonical asset update

Source-of-truth rules determine which fields may overwrite others:

- Technical facts come from the freshest high-confidence technical observation.
- Business owner, criticality, classification and compliance scope remain governed fields and are not overwritten by discovery.
- CMDB may be authoritative for ownership/location if configured by the tenant.
- Every canonical field stores provenance, confidence and observation time.

Missing assets should become stale before being retired. One failed scan must never delete an asset.

Stage 10 — Software inventory and application relationships

Each installation should be represented as a structured record:

- Canonical software product ID.
- Raw name and publisher.
- Version and edition.
- Installation path where permitted.
- CPE and PURL candidates.
- Discovery source.
- First seen and last seen.
- Host asset ID.
- Confidence.

Only security-relevant server applications should normally become separate child assets. Common desktop packages remain software installations unless the tenant explicitly promotes them.

Stage 11 — CIS routing

Use normalized OS and software keys to select applicable CIS benchmarks. Trigger assessment only when:

- A new asset appears.
- OS family/build changes.
- Relevant software is installed, upgraded or removed.
- A benchmark/rule version changes.
- The scheduled reassessment interval expires.

This prevents unnecessary execution across all 30,000 assets.

Stage 12 — Vulnerability correlation

Generate or ingest CPE/PURL identifiers, compare installed versions with vulnerability intelligence and create evidence-backed asset-vulnerability links. Store why the match occurred and its confidence. Scanner results remain

an additional authoritative source and should reconcile with inventory-based matches.

Stage 13 — Risk and workflow

After relevant changes, recalculate:

- CIS compliance gap.
- Vulnerability exposure using CVSS, EPSS and KEV.
- Internet/network exposure.
- Business criticality and regulated-data impact.
- Existing control coverage and accepted risks.

Generate workflows for events such as:

- New unmanaged device.
- Critical asset missing an agent.
- Unsupported operating system.
- High-risk software newly installed.
- Critical CIS regression.
- Asset unseen beyond its stale threshold.

7. Target architecture

7.1 Control plane

The ComplyVerse backend owns:

- Campaign configuration and authorization.
- Job orchestration and scheduling.
- Collector registration and health.
- Identity resolution and normalization.
- Canonical inventory.
- CIS, vulnerability and risk integration.
- Dashboards, workflow and audit records.

7.2 Customer-side collector

Banks should deploy one or more hardened collectors as Linux/Windows services or virtual appliances. Each collector:

- Initiates outbound TLS communication to ComplyVerse.
- Polls or receives signed job assignments.
- Accesses only assigned scopes.
- Retrieves credentials from a local/encrypted vault.
- Executes protocol-specific workers.
- Encrypts and uploads bounded result batches.
- Maintains no long-term plaintext secrets.
- Reports health, capacity and version.

No bank should be required to expose WinRM, SSH or SNMP to the public internet.

7.3 Worker types

- Presence worker: ARP/ICMP/TCP/UDP/DNS.
- Windows worker: WinRM and PowerShell.
- Linux worker: SSH.
- Network worker: SNMPv3 and vendor-specific APIs.
- Directory worker: LDAP/Active Directory.
- Virtualization worker: vCenter.
- Cloud worker: AWS/Azure/GCP APIs.
- CMDB worker: BMC/ServiceNow/ManageEngine.
- Agent-job worker: local endpoint checks.

7.4 Queue design

Campaigns should be decomposed into bounded tasks:

```
Campaign
→ scope enumeration jobs
→ subnet chunks
→ presence jobs
→ fingerprint jobs
→ authenticated inventory jobs
→ normalization/identity jobs
→ CIS/CVE/risk jobs
```

Jobs require idempotency keys, retry policies, leases, heartbeats, timeouts and dead-letter handling.

8. Required data model

Add relational tables similar to the following:

Table	Purpose
grc_discovery_collectors	Customer-side collector identity, status, version and capacity
grc_discovery_campaigns	Tenant campaign, schedule, limits and lifecycle
grc_discovery_scopes	CIDRs, OUs, cloud scopes, exclusions and protocol policy
grc_credential_profiles	Encrypted references and applicability rules; never return secrets to UI
grc_discovery_runs	One execution of a campaign with aggregate status
grc_discovery_jobs	Durable unit of work, lease, retry and progress
grc_discovery_observations	Raw evidence from every source
grc_asset_external_identities	Stable identifiers mapped to canonical assets
grc_asset_source_records	Source-specific records and authority policy
grc_asset_inventory_snapshots	Versioned inventory collection metadata
grc_asset_interfaces	Network adapters, MAC/IP and first/last seen
grc_software_products	Canonical publisher/product catalog
grc_software_installations	Product/version installed on a host with provenance
grc_asset_services	Services/listening ports and process evidence

Table	Purpose
grc_asset_relationships	Host/application, VM/hypervisor, interface/network and dependency links
grc_asset_change_events	Added, removed or modified inventory facts
grc_identity_merge_reviews	Possible duplicates and human decisions

Do not store the long-term software inventory only in `detected_software.json`. JSON may remain as a transitional cache, but relational installation rows are needed for searching, history, correlation and scale.

9. API surface

Recommended API groups:

- POST/GET/PATCH `/asset-intelligence/campaigns`
- POST `/asset-intelligence/campaigns/{id}/run`
- POST `/asset-intelligence/runs/{id}/pause|resume|cancel`
- GET `/asset-intelligence/runs/{id}/progress`
- POST/GET `/asset-intelligence/collectors`
- POST `/asset-intelligence/collectors/{id}/heartbeat`
- GET `/asset-intelligence/collectors/{id}/jobs`
- POST `/asset-intelligence/jobs/{id}/results`
- POST/GET `/asset-intelligence/credential-profiles`
- GET `/asset-intelligence/observations`
- GET `/asset-intelligence/duplicates`
- POST `/asset-intelligence/duplicates/{id}/merge|dismiss`
- GET `/assets/{id}/inventory-history`
- GET `/assets/{id}/software-installations`
- GET `/assets/{id}/provenance`

Collector endpoints should use collector certificates/tokens and never user-session authentication.

10. User interface plan

Create an **Asset Intelligence** administration workspace with:

Overview

- Known canonical assets.
- Newly discovered assets.
- Unmanaged/unauthenticated devices.
- Stale assets.
- Coverage by source and collection method.
- Collector health.
- Last campaign outcomes.

Campaigns

- Campaign list, schedule and current status.
- Guided campaign creation.
- Scope/exclusion preview.
- Run, pause, resume and cancel actions.
- Historical comparisons.

Live run

- Stage-based progress.
- Counts for candidate, alive, fingerprinted, authenticated, inventoried, merged, new and failed.
- Failure categories and retry controls.
- Per-collector throughput.

Collectors

- Online/offline state.
- Version and upgrade state.
- Assigned networks and capabilities.
- Current load and last heartbeat.

Identity review

- Possible duplicate pairs.
- Evidence comparison.
- Merge, keep separate or defer.

Asset detail additions

- Identity and provenance.
- Hardware and interfaces.
- Installed software with version history.
- Services and ports.
- Discovery/collection history.
- Collection failures and remediation guidance.

11. Security and bank-readiness requirements

Credential safety

- Use a dedicated encryption key or external secrets manager/HSM.
- Separate credentials by tenant.
- Prefer credential references over copies per host.
- Never log, return or include secrets in job payload diagnostics.
- Support rotation and immediate revocation.

- Record who created, changed and used a profile without exposing its value.

Collector safety

- Mutual TLS or equivalent signed device identity.
- Outbound-only connectivity from customer environments.
- Signed jobs with tenant, scope and expiry.
- Collector allowlist enforcement independent of the cloud command.
- Signed upgrades and controlled rollout.
- Local service hardening and minimal privileges.

Scan safety

- Explicit scope approval and exclusions.
- Rate limiting per subnet and target.
- Maintenance windows.
- Account-lockout protection.
- Read-only collection commands.
- Maximum output, duration and concurrent sessions.
- Emergency stop at campaign and collector levels.

Governance

- Tenant isolation in every table and query.
- Role permissions for configuration, execution, credential management and review.
- Immutable audit trail.
- Configurable inventory retention.
- Data residency and regional collector support.

12. Scale design for 30,000 assets

The existing synchronous discovery endpoint is unsuitable for this target. Required principles:

- Background all campaign work.
- Split address ranges into small chunks, typically 128–512 candidates.
- Use multiple collectors by site or network zone.
- Bound concurrency separately for discovery, WinRM, SSH and SNMP.
- Stream results in batches rather than one giant response.
- Use database bulk upsert operations.
- Index tenant plus identity, last-seen, OS and software lookup fields.
- Partition or archive high-volume observations and snapshots.
- Store change events so unchanged snapshots need not duplicate every fact indefinitely.
- Recalculate CIS/CVE/risk incrementally.
- Apply backpressure when backend ingestion or a customer network is saturated.

Initial performance targets:

Measure	Initial target
Campaign scope	30,000 canonical assets
Discovery result loss	0 accepted jobs lost after acknowledgement
Duplicate rate after repeated run	Below 0.5%, with review queue for ambiguity
Collector availability	99.5% during scheduled windows
Inventory freshness	95% of reachable managed assets within 24 hours
UI progress latency	Under 10 seconds
Result ingestion	At least 100 inventory results/minute per backend deployment, horizontally scalable

These targets must be validated through staged load tests rather than assumed.

13. Delivery roadmap

Phase 0 — Design and hardening decisions (2 weeks)

Deliverables:

- Confirm product terminology and supported first-release platforms.
- Threat model and bank network deployment model.
- Source-of-truth and deduplication rules.
- Schema and API design review.
- Collector packaging decision.
- Test environment with Windows domain and Linux hosts.

Exit criteria: approved architecture, schema, threat model and acceptance tests.

Phase 1 — Discovery foundation (4–6 weeks)

Deliverables:

- Campaign, scope, run, job, collector and observation tables.
- Background campaign orchestration.
- Collector registration, heartbeat and job lease protocol.
- Convert existing CIDR logic into collector jobs.
- Progress UI with pause/resume/cancel/retry.
- Audit and permission model.

Exit criteria: a queued campaign can safely discover approved ranges, survive worker restart and display durable progress.

Phase 2 — Windows vertical slice (5–7 weeks)

Deliverables:

- Scheduled AD enumeration.
- WinRM credential profiles and safe profile selection.
- Windows hardware/OS/software collection through collector.

- Stable Windows identity resolution.
- Structured software-installation storage.
- Automatic CIS and vulnerability triggers.
- Full asset provenance and collection history UI.

Exit criteria: 1,000 Windows hosts can be repeatedly processed without duplicate creation, credential exposure or lost results.

Phase 3 — Linux and agent convergence (4–6 weeks)

Deliverables:

- SSH credential profiles and inventory.
- Complete endpoint-agent job dispatch and result lifecycle.
- Common normalized payload contract for agent and agentless collection.
- Fleet policy, agent health and upgrade controls.

Exit criteria: Windows/Linux agent and agentless results produce equivalent canonical inventory.

Phase 4 — Network, virtualization and topology (6–8 weeks)

Deliverables:

- Real SNMPv3 discovery and inventory.
- Switch/router/firewall classification.
- Interface and neighbor relationships.
- vCenter inventory and stable VM identities.
- Network and infrastructure relationship visualization.

Exit criteria: supported network devices and VMs are identified without relying on IP as their permanent identity.

Phase 5 — CMDB reconciliation and enterprise operations (4–6 weeks)

Deliverables:

- BMC and ServiceNow asset synchronization through the normalized pipeline.
- Configurable field authority.
- Conflict and drift reporting.
- Stale/unmanaged/unknown asset workflows.
- Campaign analytics and operational SLO reporting.

Exit criteria: customers can use ComplyVerse with or without an existing ITAM and reconcile differences visibly.

Phase 6 — 30K scale and production certification (4–6 weeks)

Deliverables:

- 30,000-asset load and endurance testing.
- Database/index optimization.
- Multi-collector failover testing.
- Penetration test and threat-model closure.
- Backup/restore and disaster recovery validation.

- Deployment, operations and bank approval documentation.

Exit criteria: agreed scale, security and recovery acceptance tests pass.

Estimated total: approximately **29–41 engineering weeks** for a production-grade breadth of coverage. Multiple engineers can execute selected workstreams concurrently, but identity, security and orchestration foundations should not be rushed.

14. Recommended first release

The first commercially useful release should focus on:

- Windows domain environments.
- Active Directory enumeration.
- Collector-based WinRM inventory.
- Optional endpoint agent.
- Structured software inventory.
- Identity resolution and repeat-run deduplication.
- Existing CIS, CVE and risk integration.
- Campaign progress, failures and audit trail.

It should not claim universal network discovery. Linux support can follow immediately, while SNMP/network-device and vCenter coverage enter subsequent releases.

15. Acceptance criteria for the Windows vertical slice

Functional

- Administrator can register a collector and create a campaign.
- AD returns scoped computer accounts using pagination.
- The campaign inventories reachable selected hosts through WinRM.
- Offline hosts remain known and receive a failed/stale observation.
- Repeated campaigns update, rather than duplicate, the same machine.
- Installed software additions, removals and upgrades generate change events.
- Relevant CIS assessments and CVE mappings run automatically.
- Asset detail shows provenance, last collection and failures.

Security

- Secrets never appear in API responses, application logs or job error text.
- Collector cannot execute jobs outside its signed allowlist.
- A revoked collector or credential cannot obtain new jobs.
- All operator and collector actions are tenant-scoped and audited.
- Account-lockout thresholds are configurable and enforced.

Reliability

- Restarting backend, queue worker or collector does not lose acknowledged work.

- Duplicate result submission is idempotent.
- Individual targets can be retried without repeating the whole campaign.
- A partially failed campaign produces useful successful inventory.

Performance

- 1,000-host test completes inside the agreed bank scan window.
- UI remains responsive and progress updates within 10 seconds.
- The backend accepts bounded result batches without excessive memory use.

16. Major risks and controls

Risk	Control
Duplicate assets	Strong external identities, confidence scoring and merge review
Network disruption	Rate limits, exclusions, safe defaults, maintenance windows and emergency stop
Account lockout	Credential preflight, attempt limits and lockout-aware backoff
Credential compromise	Local/encrypted vault, least privilege, rotation and no secret logging
Incorrect fingerprint	Preserve evidence/confidence; authenticated data overrides guesses
Inventory volume	Batch upserts, indexes, retention and incremental change storage
Collector compromise	Signed identity/jobs/upgrades, allowlist and minimal privilege
Incorrect CVE matching	Store match evidence and confidence; reconcile scanner confirmation
Scope creep toward EDR	Maintain the non-intrusive inventory/compliance boundary for initial releases

17. Immediate engineering backlog

The first backlog should be executed in this order:

- 1 Approve schema and identity hierarchy.
- 2 Add campaign/run/job/collector/observation migrations.
- 3 Define versioned collector job and result payloads.
- 4 Build collector authentication, heartbeat and job leasing.
- 5 Move CIDR work from synchronous API execution to background collector jobs.
- 6 Add run progress, retry and cancellation.
- 7 Feed AD candidates into the same campaign pipeline.
- 8 Implement Windows stable identity collection.
- 9 Introduce structured software product/installation tables.
- 10 Route WinRM inventory through campaign jobs and credential profiles.
- 11 Connect inventory changes to CIS, CPE/PURL and risk recalculation.
- 12 Add provenance, history and failure panels to asset detail.
- 13 Complete Windows load, failure and security testing.

18. Final recommendation

Do not build a giant scanner first. Build a durable **identity and orchestration backbone**, then plug discovery methods into it.

CIDR should remain one optional candidate source. For a bank, the most valuable first pipeline is:

```
Active Directory
→ Discovery Campaign
→ Customer-side Collector
→ WinRM Inventory
→ Identity Resolution
→ Software Inventory
→ CIS and CVE Correlation
→ Risk Prioritization
→ GRC Workflow
```

That pipeline creates a differentiated GRC product: ComplyVerse can consume an existing BMC/ServiceNow inventory when available, but it can also build and continuously validate its own evidence-backed inventory when no ITAM exists.